PLAN DE RESPUESTA A INCIDENTES

GV.OC — Gobernanza y Contexto Organizacional

GV.OC-01 — Misión y Alineación Estratégica

La misión organizacional se entiende y se integra en la gestión de riesgos de ciberseguridad. TECNOMARKET orienta sus esfuerzos hacia la continuidad operativa, la protección de activos críticos y la resiliencia frente a amenazas. La gestión de riesgos se guía por la necesidad de mantener la estabilidad del negocio, proteger su infraestructura digital y asegurar la integridad de los servicios que ofrece a clientes y socios. Esta alineación estratégica permite que las decisiones tomadas durante un incidente estén respaldadas por objetivos corporativos claros.

GV.OC-02 — Partes Interesadas Internas y Externas

La organización identifica y comprende a todas las partes interesadas relevantes, incluyendo empleados, áreas operativas, proveedores tecnológicos, clientes y entidades regulatorias. Se consideran sus expectativas en cuanto a confidencialidad, disponibilidad y recuperación ante incidentes. La dependencia crítica hacia Azure como plataforma central implica que cualquier incidente en endpoints locales podría escalar y comprometer información alojada en la nube, por lo que las decisiones de mitigación consideran tanto el entorno local como el cloud.

GV.OC-03 — Requisitos Legales, Regulatorios y Contractuales

TECNOMARKET reconoce sus obligaciones bajo la Ley Federal de Protección de Datos Personales en Posesión de los Particulares, la Ley Federal de Protección al Consumidor y el Código Penal Federal en materia de delitos informáticos. Estos marcos establecen requisitos sobre privacidad, manejo de datos sensibles, protección de consumidores y responsabilidad ante incidentes de seguridad. La organización implementa controles alineados a estos requisitos y asegura que su respuesta a incidentes considere la posible exposición de datos personales, credenciales o información de clientes y colaboradores.

GV.OC-04 — Objetivos Críticos, Capacidades y Servicios Dependientes

La continuidad del negocio y la mitigación de vulnerabilidades de firmware constituyen los objetivos críticos frente al incidente analizado. Se identifica el impacto potencial sobre áreas administrativas y operativas debido a la explotación de vulnerabilidades en equipos HP. La empresa depende fuertemente de Azure para sus servicios esenciales: bases de datos, identidades, lógica del negocio y aplicaciones

web. Por ello, la respuesta prioriza el aislamiento rápido de endpoints comprometidos, la protección de credenciales y la verificación de integridad en servicios cloud, evitando que el incidente escale.

GV.OC-05 — Dependencias Críticas y Servicios Externos

La organización reconoce como dependencias esenciales los servicios provistos por Azure, incluyendo Azure AD, Azure SQL, App Service y Static Web Apps. El compromiso de cualquiera de estos servicios tendría consecuencias operativas significativas. TECNOMARKET mantiene comunicación activa con proveedores y establece mecanismos para reportar anomalías de forma oportuna. Estas dependencias influyen directamente en la priorización de actividades de respuesta y recuperación, especialmente en escenarios en los que endpoints locales actúan como puerta de entrada hacia los servicios en la nube.

ID.RA

ID.RA — Evaluación de Riesgos (01–05)

ID.RA-01 — Identificación de Vulnerabilidades

La organización mantiene un inventario formal, documentado y actualizado de vulnerabilidades conocidas y potenciales que afectan a los activos tecnológicos críticos.
Este inventario incluye:

- Vulnerabilidades específicas identificadas mediante CVEs relevantes, especialmente asociadas a firmware, servicios en la nube, autenticación y arquitectura de TI (documento: *“ACTIVOS A DEFENDER”*).
- Vulnerabilidades generales relacionadas con software, hardware, configuraciones deficientes, diseño inseguro de redes, debilidades en autenticación, exposición de servicios y dependencias tecnológicas (documento: *“Vulnerabilidades de Activos Tecnológicos – General”*).

Estos insumos permiten a la organización comprender su superficie de ataque actual y establecer una base precisa para la evaluación de riesgos inherentes, cumpliendo con los requisitos de ID.RA-01 al conocer las debilidades que podrían ser explotadas para comprometer la confidencialidad, integridad y disponibilidad de los activos.

ID.RA-02 — Inteligencia de Amenazas Cibernéticas (CTI)

La organización integra prácticas básicas de Inteligencia de Amenazas Cibernéticas (CTI) para comprender el contexto operativo de amenazas internas y externas, los actores involucrados, las vulnerabilidades explotadas y los TTP (tácticas, técnicas y procedimientos) documentados por la comunidad internacional de ciberseguridad.

Las fuentes CTI utilizadas incluyen:

- **Repositorios y estándares de referencia:** MITRE ATT&CK, CISA KEV, información de CVEs.
- **Organizaciones y comunidades:** FIRST, ISC2, Cisco Talos, SecurityNewsWire.
- **Fuentes adicionales sugeridas para el futuro:** STIX/TAXII, MISP para automatización.

La organización ha establecido un sistema básico de gestión de CTI compuesto por:

1. **Estructura interna de directorios** para almacenar CVEs, TTP, campañas de malware, incidentes de phishing y actualizaciones críticas de firmware.
2. **Un procedimiento inicial de CTI** que define cómo recolectar, clasificar y evaluar inteligencia de amenazas relevante.
3. **Integración de la CTI** como insumo directo para:
    - La evaluación de riesgos (ID.RA),
    - La mejora continua de controles (PR.IP),
    - La vigilancia de seguridad (DE.CM),
    - Y la respuesta a incidentes (RS).

Aunque en etapa inicial, la organización cuenta con los elementos esenciales para desarrollar inteligencia contextualizada y apoyar decisiones oportunas ante amenazas emergentes.

ID.RA-03 — Identificación de Amenazas Internas y Externas

La organización identifica, registra y evalúa amenazas internas y externas mediante información proveniente de:

- Operaciones de TI,
- CTI estructurada,

- Observaciones de alertas técnicas (SIEM, antivirus, logs),
- Actividades básicas de threat hunting,
- Y revisiones periódicas de incidentes previos.

Amenazas externas consideradas:

- Phishing, malware, robo de credenciales.
- Explotación de vulnerabilidades de firmware y servicios en la nube.
- Técnicas documentadas en MITRE ATT&CK (movimiento lateral, persistencia, ejecución remota).
- Compromiso de cadenas de suministro tecnológicas.
- Ataques a la infraestructura en la nube, especialmente Azure AD.

Amenazas internas consideradas:

- Errores operativos que generan exposición de datos o configuraciones.
- Usuarios con privilegios excesivos o cuentas sin supervisión.
- Riesgos derivados de personal descontento o negligente.

Se consideran métodos complementarios como actividades de **caza de amenazas** y potencial uso futuro de **tecnologías de engaño** (ej. honeypots, honeytokens).

Toda amenaza identificada se vincula con vulnerabilidades documentadas, activos afectados y escenarios plausibles de explotación, alimentando así la matriz de riesgos.

ID.RA-04 — Evaluación de Probabilidad e Impacto

Una vez identificadas amenazas y vulnerabilidades, la organización evalúa la probabilidad y el impacto potencial de su explotación mediante una matriz de riesgos diseñada para clasificar:

- Probabilidad (Baja, Media, Alta),
- Impacto en Confidencialidad, Integridad y Disponibilidad,
- Impacto total resultante.

Esta matriz permite:

- Visualizar el riesgo inherente,
- Identificar escenarios críticos,
- Priorizar esfuerzos de mitigación,
- Y proveer insumos claros para la toma de decisiones ejecutivas.

La matriz ha sido construida a nivel organizacional considerando los activos más relevantes y el contexto actual de la empresa.

ID.RA-05 — Comprensión del Riesgo Inherente y Priorización

Los resultados de probabilidades e impactos se integran para determinar el nivel de riesgo inherente asociado a cada amenaza y vulnerabilidad.
Este análisis consolida:

- Activos afectados,
- Amenazas aplicables,
- Vulnerabilidades correspondientes,
- Probabilidad de explotación,
- Impacto estimado,
- Nivel de riesgo (bajo, medio, alto, crítico).

La información resultante se comunica a los responsables de TI y a la dirección para priorizar la mitigación, asignar recursos y orientar la toma de decisiones estratégicas.

ID.RA-06 — Selección, priorización y seguimiento de respuestas al riesgo

La organización cuenta con un proceso formal para seleccionar, priorizar y planificar las respuestas al riesgo identificado, de acuerdo con los cuatro enfoques establecidos por el NIST: aceptar, mitigar, transferir o evitar.

Durante la evaluación de riesgos se identificaron vulnerabilidades de firmware, configuraciones incorrectas y riesgos relacionados con servicios en la nube (Azure). Estas debilidades fueron registradas y priorizadas; sin embargo, al momento del incidente algunas acciones de tratamiento se encontraban **pendientes de implementación** o en proceso de planificación.

Este escenario refleja una situación común en organizaciones con madurez intermedia, en donde el proceso de gestión de riesgos está establecido, pero aún se encuentra en **etapas tempranas de ejecución**, lo que permite que ciertos riesgos persistan y eventualmente se materialicen en un incidente.

La información generada a partir de esta evaluación se comunica a la dirección y sirve como insumo para definir planes de mitigación, asignar responsabilidades y realizar seguimiento continuo, con el objetivo de fortalecer la postura de seguridad y evitar la recurrencia del incidente.

ID.RA-07 — Gestión de cambios y excepciones

La organización mantiene un proceso formal para gestionar y evaluar los cambios que puedan alterar el perfil de riesgo de los activos tecnológicos. Cualquier modificación en infraestructura, software, configuraciones, arquitectura de red, proveedores o servicios en la nube se somete a una evaluación previa para determinar su impacto en la confidencialidad, integridad y disponibilidad de la información.

Asimismo, cuando un control de seguridad no puede aplicarse (por limitaciones técnicas, operativas o presupuestales), se documenta una **excepción de seguridad** que incluye:

1. La justificación de la excepción
2. El riesgo residual asociado
3. Las compensaciones o controles temporales aplicados
4. El responsable de su aprobación

5. La fecha de expiración y revisión

Todas las excepciones y cambios aprobados se registran, se rastrean y se revisan periódicamente para determinar si el riesgo asociado ha aumentado o disminuido, o si se requiere implementar controles adicionales. Este proceso asegura que las decisiones operativas se realicen con visibilidad del riesgo inherente y contribuyen a evitar incidentes derivados de configuraciones no controladas o controles faltantes.

ID.RA-08 — Procesos para recibir, analizar y responder a divulgaciones de vulnerabilidad

La organización ha establecido un proceso básico y formalizado para recibir, analizar y responder a divulgaciones de vulnerabilidades provenientes de terceros, tales como investigadores independientes, proveedores, clientes, especialistas externos o personal interno.

Con el fin de facilitar la comunicación responsable, se habilitó el canal oficial **security@tecnomarket.com**, el cual funciona como punto de contacto único para el reporte de posibles fallas en sistemas, aplicaciones, infraestructura, servicios en la nube y activos tecnológicos asociados a TECNOMARKET.

Este canal permite que cualquier tercero notifique sospechas de vulnerabilidades de manera segura, estructurada y controlada, sin exponer la información al público ni incrementar el riesgo operativo.

Para ello, la organización desarrolló un **Formato de Divulgación de Vulnerabilidades**, el cual instruye a los reportantes sobre la información mínima requerida para procesar adecuadamente un hallazgo (descripción técnica, evidencia, activo afectado, impacto potencial, pruebas realizadas sin explotación activa, etc.).

Asimismo, el proceso contempla:

- **Recepción inicial** del reporte mediante el correo oficial.
- **Registro y categorización** del hallazgo en el sistema interno de gestión de riesgos.
- **Análisis técnico preliminar** por parte del equipo responsable.

- **Evaluación del riesgo** utilizando la matriz de clasificación de riesgos establecida en ID.RA (impacto, probabilidad, criticidad).
- **Respuesta coordinada** hacia el reportante, confirmando la recepción, solicitando evidencia adicional o notificando la resolución.
- **Gestión de remediación** mediante acciones correctivas alineadas a las respuestas al riesgo (mitigar, aceptar, transferir o evitar).

Este proceso permite que la organización detecte fallas antes de que sean explotadas, mantenga un ciclo de mejora continua y promueva prácticas responsables de divulgación, similares a las implementadas en programas de bug bounty formales.

ID.RA-09 — Evaluación de autenticidad e integridad de hardware y software antes de su adquisición y uso

La organización establece un proceso básico para verificar la autenticidad e integridad del hardware y software antes de su puesta en operación. Este proceso aplica a todos los equipos adquiridos mediante proveedores autorizados y tiene como objetivo reducir riesgos asociados a manipulación previa, hardware falsificado, firmware alterado o componentes no legítimos.

Al recibir hardware nuevo (por ejemplo, computadoras portátiles, periféricos o dispositivos de red), el área de TI ejecuta una revisión estructurada que incluye validación física, verificación de números de serie con el proveedor, inspección del estado del empaque, evaluación de firmware inicial y confirmación del software preinstalado. Esta verificación se documenta y se archiva antes de distribuir los equipos a los usuarios finales.

ID.IM

ID.IM — Estrategia de Gestión del Riesgo

La organización evalúa de forma continua la eficacia de sus actividades de gestión de riesgos de ciberseguridad, con el fin de identificar oportunidades de mejora y asegurar la alineación con los objetivos operativos y de seguridad de TECNOMARKET. A partir de las lecciones aprendidas derivadas de incidentes, hallazgos de CTI, resultados de evaluaciones de vulnerabilidades y revisiones periódicas del plan de respuesta, se actualizan los criterios, procedimientos y controles asociados al riesgo.

Esta estrategia incluye la revisión sistemática de:

- **Criterios de evaluación del riesgo**, incluyendo niveles de impacto, probabilidad y clasificación de criticidad.
- **Procesos y procedimientos de identificación, análisis y tratamiento del riesgo**, para garantizar que reflejen amenazas emergentes, tecnología adoptada y cambios operativos.
- **Controles implementados** (preventivos, detectivos y correctivos), verificando su suficiencia y oportunidad frente a riesgos conocidos y nuevos.
- **Roles y responsabilidades**, asegurando que las funciones relacionadas con la gestión de riesgo estén correctamente asignadas y actualizadas.
- **Registros de riesgos y matrices**, que se revisan y ajustan cuando se modifican los escenarios de riesgo, las amenazas, o las dependencias tecnológicas.

El resultado de estas revisiones es documentado y comunicado a la dirección y a los responsables de áreas involucradas, para asegurar que las decisiones estratégicas se basen en información vigente. Esta mejora continua fortalece la resiliencia operativa, reduce la probabilidad de incidentes repetidos y consolida el ciclo integral de gestión del riesgo dentro de la organización.

ID.IM-01 — Identificación de mejoras a partir de evaluaciones

La organización realiza evaluaciones periódicas del programa de gestión de riesgos y del proceso de respuesta a incidentes con el fin de identificar deficiencias, áreas de

mejora y oportunidades para fortalecer la postura de seguridad de TECNOMARKET. Estas evaluaciones permiten validar si los controles existentes funcionan conforme a lo esperado, si los procedimientos son adecuados para el entorno operativo y si las prácticas actuales permiten responder con eficacia ante amenazas emergentes.

Para ello, se consideran múltiples mecanismos de evaluación, tales como:

- **Autoevaluaciones internas**, realizadas por el personal de TI y Ciberseguridad, revisando métricas, incidentes recientes, vulnerabilidades detectadas y rendimiento de los controles.
- **Evaluaciones de terceros**, incluyendo pruebas de penetración, ejercicios de red team, consultorías especializadas o revisiones técnicas independientes.
- **Auditorías externas**, enfocadas en verificar el cumplimiento de marcos normativos, políticas internas y mejores prácticas de la industria.
- **Ejercicios de simulación y tabletop**, que permiten medir la capacidad operativa del equipo ante incidentes realistas y revelar brechas en comunicación, detección o contención.

Los resultados de estas evaluaciones alimentan directamente el ciclo de mejora continua del programa de gestión de riesgos, asegurando que los procedimientos, controles y políticas se ajusten a las amenazas actuales, el contexto tecnológico y los recursos de la organización. Todas las observaciones y hallazgos se documentan y se integran a los planes de acción para su seguimiento, priorización y corrección

ID.IM-02 — Pruebas y ejercicios de seguridad

Texto para incluir en el Plan de IR

La organización reconoce que las pruebas y ejercicios de seguridad constituyen una de las fuentes más valiosas para detectar fallas, brechas de coordinación y oportunidades de mejora en el programa de respuesta a incidentes.

Con base en ello, TECNOMARKET mantiene el compromiso de realizar ejercicios periódicos orientados a validar la efectividad del personal, los procedimientos, los tiempos de reacción y la coordinación con proveedores o terceros involucrados en la operación.

Los ejercicios pueden incluir, según disponibilidad de recursos:

- **Simulaciones de incidente (tabletop exercises)** basadas en escenarios relevantes para la organización, tales como explotación de vulnerabilidades críticas, fallas de servicios en la nube o exposición de credenciales.
- **Pruebas técnicas controladas**, tales como análisis de vulnerabilidades, escaneos autenticados o ejercicios internos limitados de threat hunting.
- **Coordinación con terceros críticos**, como proveedores de infraestructura en la nube, soporte de hardware o servicios externos de TI, con el fin de validar la integración de procesos y el flujo de comunicación.
- **Revisión posterior al ejercicio**, donde se documentan los aprendizajes, deficiencias identificadas y recomendaciones generadas.

Los resultados de estas pruebas alimentan directamente los procesos de mejora continua del programa de IR descritos en ID.IM-01, permitiendo fortalecer controles preventivos, optimizar procedimientos y preparar al personal para escenarios reales de incidente.

ID.IM-03 — Identificación de mejoras a partir de la ejecución operativa

Durante la ejecución real de procesos, procedimientos y actividades operacionales de respuesta y recuperación ante incidentes, la organización identifica oportunidades de mejora destinadas a fortalecer continuamente su programa de gestión de riesgos de ciberseguridad. Cada incidente registrado, sin importar su severidad, constituye una fuente directa de retroalimentación sobre el desempeño real de los controles, la coordinación entre equipos, la efectividad de los procedimientos establecidos y la capacidad de detección y contención de la organización.

Las mejoras identificadas pueden incluir ajustes en:

- El **Plan de Respuesta a Incidentes** y sus procedimientos específicos.
- La configuración y efectividad de los controles preventivos y detectivos (PR.IP, DE.CM).
- Los flujos de trabajo y roles de comunicación (RS.CO).
- Las prácticas de gestión de riesgos de la organización, especialmente cuando se detectan TTP que no están siendo bloqueados ni alertados por las herramientas actuales.

Estas mejoras se derivan principalmente de dos mecanismos operativos:

1. **Informes de seguimiento post-incidente**, donde se analiza formalmente qué ocurrió, cómo se gestionó el evento y qué elementos fueron deficientes o exitosos.
2. **Reuniones de lecciones aprendidas**, celebradas al finalizar las actividades de recuperación, en las que participan todos los involucrados para validar decisiones, revisar evidencias y documentar recomendaciones.

El análisis post-incidente permite incorporar mejoras inmediatas y estructurales, y asegura que los aprendizajes derivados de la operación diaria se integren al ciclo completo de gestión de riesgos, fortaleciendo progresivamente la resiliencia organizacional.

ID.IM-04 — Integración, mantenimiento y mejora de planes de ciberseguridad

La organización establece, comunica, mantiene y mejora de forma continua los planes de respuesta a incidentes y los planes complementarios de ciberseguridad que influyen directamente en la estabilidad operativa, la resiliencia y la continuidad del negocio.

TECNOMARKET mantiene tres tipos principales de planes interrelacionados:

1. **Plan de Respuesta a Incidentes (IRP)**, que define los roles, responsabilidades, procesos y actividades necesarias para detectar, analizar, contener, erradicar y recuperarse de incidentes de ciberseguridad.
2. **Plan de Gestión de Vulnerabilidades**, que proporciona el marco sistemático para identificar, evaluar, priorizar y corregir vulnerabilidades, incluyendo firmware, configuraciones, software, servicios en la nube y componentes de terceros.
3. **Plan de Continuidad del Negocio (BCP)**, responsable de asegurar que las funciones críticas continúen operando o puedan recuperarse rápidamente frente a interrupciones.

Estos planes se mantienen alineados entre sí para asegurar una respuesta coherente y coordinada durante interrupciones tecnológicas o incidentes de ciberseguridad. En particular, el IRP se sincroniza con el BCP debido a que incidentes como ransomware,

fallas de disponibilidad, ataques DoS o compromiso de servicios en la nube pueden afectar significativamente los tiempos de recuperación y la operación general de la organización.

Cada plan se basa en las características particulares de TECNOMARKET (misión, tamaño, estructura, recursos y funciones críticas), y define los recursos humanos, tecnológicos y de gestión necesarios para su ejecución. Asimismo, todos los planes se revisan periódicamente o cuando se detecta la necesidad de incorporar mejoras derivadas de incidentes, auditorías, cambios tecnológicos o nuevos riesgos identificados.

La retroalimentación obtenida de los planificadores de continuidad del negocio es especialmente valiosa, ya que permite fortalecer evaluaciones de impacto, planes de recuperación y estrategias destinadas a minimizar interrupciones durante incidentes graves. Su experiencia facilita también la planificación de respuestas frente a ataques específicos, como situaciones de denegación de servicio.

PR.AT — Concientización y Capacitación

La organización reconoce que la formación continua del personal es un componente esencial para la prevención, detección y respuesta efectiva ante incidentes de ciberseguridad. La capacitación es un mecanismo estratégico que permite reducir el riesgo humano, fortalecer la postura defensiva corporativa y asegurar que cada individuo comprenda su rol dentro del ecosistema de seguridad de la información. En el contexto de TECNOMARKET, la capacitación en ciberseguridad no es opcional ni circunstancial: es un requisito operativo para todas las áreas que interactúan con activos tecnológicos, datos críticos o procesos de negocio esenciales.

PR.AT-01 — Concientización general del personal

Todo el personal —incluyendo empleados administrativos, operaciones, ventas, TI y contratistas— recibe concientización básica en seguridad informática orientada a fomentar buenas prácticas diarias.
Este programa de concientización cubre temas fundamentales como:

- Reconocimiento de correos phishing y spear-phishing
- Manejo adecuado de contraseñas y uso de autenticación multifactor

- Prácticas de ciberhigiene en dispositivos corporativos
- Identificación y reporte de comportamientos sospechosos
- Uso responsable de recursos tecnológicos proporcionados por la empresa
- Riesgos asociados a ingeniería social y manipulación psicológica
- Seguridad básica en navegación web y redes Wi-Fi

El objetivo principal es que cada usuario sea capaz de identificar amenazas comunes y actuar adecuadamente para evitar comprometer a la organización.

PR.AT-02 — Capacitación técnica para roles específicos

El personal especializado en TI, ciberseguridad y administración de sistemas recibe formación avanzada acorde al nivel de responsabilidad del puesto.
Esta capacitación incluye:

- Gestión de vulnerabilidades
- Administración segura de Active Directory e IAM
- Detección de intrusiones, monitoreo y manejo de SIEM/EDR
- Gestión segura de infraestructura en la nube (Azure)
- Políticas de hardening en sistemas operativos, servidores y redes
- Aplicación del plan de respuesta a incidentes y roles dentro del CSIRT
- Actualización en tácticas, técnicas y procedimientos (TTP) basados en MITRE ATT&CK
- Procedimientos operativos estándar para contención, mitigación y recuperación

Con ello se garantiza que el equipo técnico tenga la competencia necesaria para responder eficazmente ante incidentes complejos.

PR.AT-03 — Capacitación alineada al Plan de Respuesta a Incidentes

La capacitación incluye módulos directamente vinculados al IR Plan, asegurando que todo el personal involucrado comprenda:

- Cómo se activa el plan de respuesta
- Qué evidencia debe preservarse
- Cómo se comunica un incidente internamente
- Cómo escalar incidentes según su criticidad
- Qué acciones están permitidas y cuáles están prohibidas durante una crisis
- Roles y responsabilidades de cada equipo durante RS.AN, RS.MI y RS.CO
- Cómo interactuar con terceros, proveedores y servicios en la nube durante la respuesta
- Documentación y registro adecuado para auditoría posterior

Esto garantiza que el proceso de respuesta no dependa de improvisaciones, sino de una comprensión clara y uniforme en toda la organización.

PR.AT-04 — Simulaciones, ejercicios y prácticas de respuesta

La organización ejecuta ejercicios periódicos para reforzar las capacidades de respuesta, incluyendo:

- Debates de mesa (tabletop)
- Simulacros de incidentes de ransomware o filtraciones de datos
- Ejercicios de phishing controlado
- Pruebas internas de respuesta operativa
- Coordinación con proveedores críticos (Azure, Odoo, Kaspersky) en simulaciones conjuntas

Estos ejercicios permiten validar el desempeño real del equipo, identificar brechas en el plan y mejorar continuamente las capacidades del CSIRT.

PR.AT-05 — Registro, evaluación y mejora continua

Todas las actividades de capacitación son documentadas y evaluadas.
La empresa mantiene:

- Registro de cursos tomados por cada empleado
- Evaluaciones periódicas del nivel de comprensión
- Indicadores de desempeño (ej. tasa de usuarios que caen en simulaciones de phishing)
- Retroalimentación al programa de capacitación en función de incidentes reales, auditorías y CTI

Las lecciones aprendidas se integran en un ciclo de mejora continua, garantizando que el programa de concientización y entrenamiento evolucione al ritmo del panorama de amenazas.